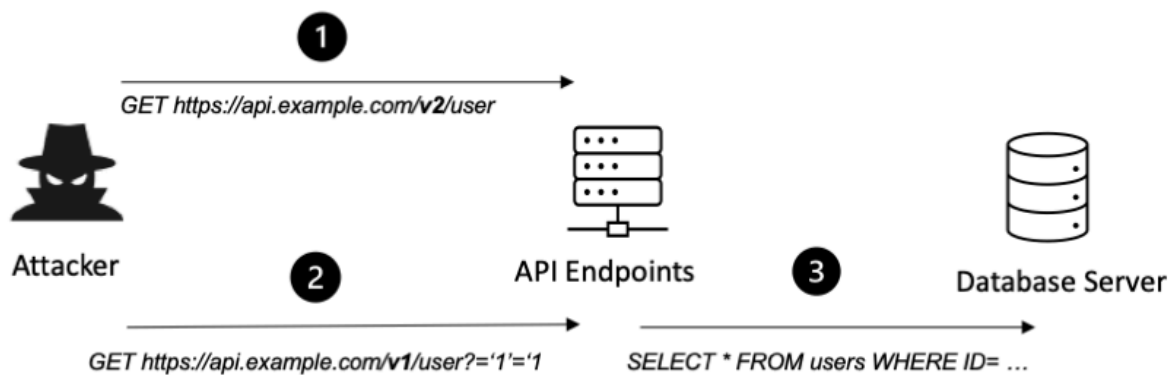


Improper Inventory Management

Introduction

What is Improper Inventory Management ?

Improper inventory management refers to the ineffective handling and tracking of API endpoints, test cases and associated test data, leading to a range of issues that can compromise the quality and reliability of the API being tested.



What is the impact of this issue ?

- **Data Breaches**
 - Attackers can exploit unmanaged APIs to gain unauthorized access to sensitive data.
- **Account Takeovers**
 - In extreme cases, attackers might even be able to take full control of servers through vulnerable APIs.

Case Study

The Forgotten v1 API

A major e-commerce company failed to properly decommission an outdated API version called **v1** after migrating their services to **v2**.

The Vulnerability (Improper Inventory Management)

The company's improper inventory management meant that the endpoint itself was never retired or access restricted. This 'zombie' API was running on an older, unpacked server and was forgotten by the development and security teams, creating a massive unmanaged shadow IT asset.

The attack

An attacker discovered the undocumented and unmonitored **/v1/user_data** endpoint. Since the API was an older version, it lacked the modern security controls like rate limiting and proper authorization checks implemented in **v2**.

Result

All of the user data from within the company was secretly scraped and leaked on the dark web. Leading to massive financial and reputational loss for the company.

Mitigations

- **Update Documentation**

- Regularly update API documentation to reflect new, deprecated or retired endpoints

- **Enforce API Version Management**

- Ensure that older API versions are properly decommissioned and no longer accessible

Conclusion

Improper Inventory Management of APIs poses a significant and often overlooked security risk. As demonstrated by the forgotten v1 API case study, unmanaged IT assets can become easy targets for attackers, leading to severe consequences like **Data Breaches** and **Account Takeovers**.

The most effective defense is a proactive and disciplined approach, which includes **Regularly Updating API Documentation** and rigorously **Enforcing API Version Management** to ensure all outdated or deprecated endpoints are properly decommissioned. Maintaining a complete and accurate inventory is essential to prevent massive financial and reputational losses.

References

<https://my.f5.com/manage/s/article/K000135762>

<https://owasp.org/API-Security/editions/2023/en/0xa9-improper-inventory-management/>